

Threat Modeling Report

Created on 4/12/2026 12:52:36 PM

Threat Model Name: SafeBank Online Banking Model

Owner: Ahmad Khokhar

Reviewer: --

Contributors: --

Description: A threat model for the SafeBank web application to identify security risks for customers checking balances and paying bills.

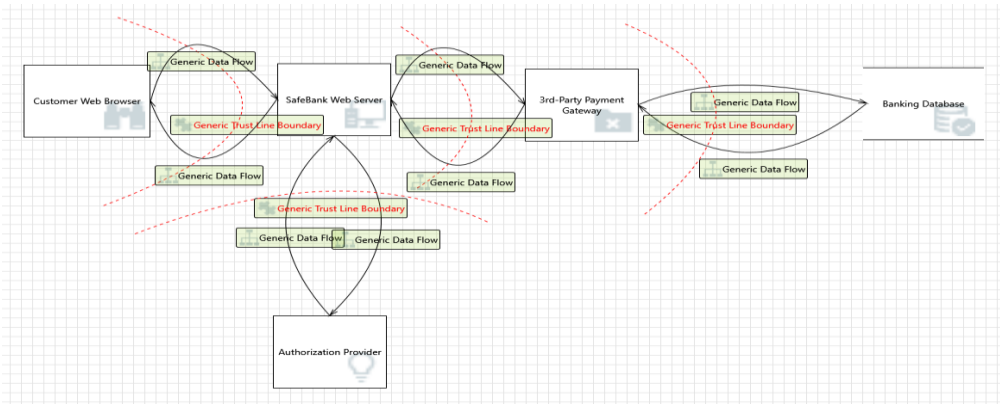
Assumptions: The system is internet-facing and all customer communications use HTTPS.

External Dependencies: 3rd-party bill payment systems via the External Payment Gateway.

Threat Model Summary:

Not Started	0
Not Applicable	0
Needs Investigation	0
Mitigation Implemented	24
Total	24
Total Migrated	0

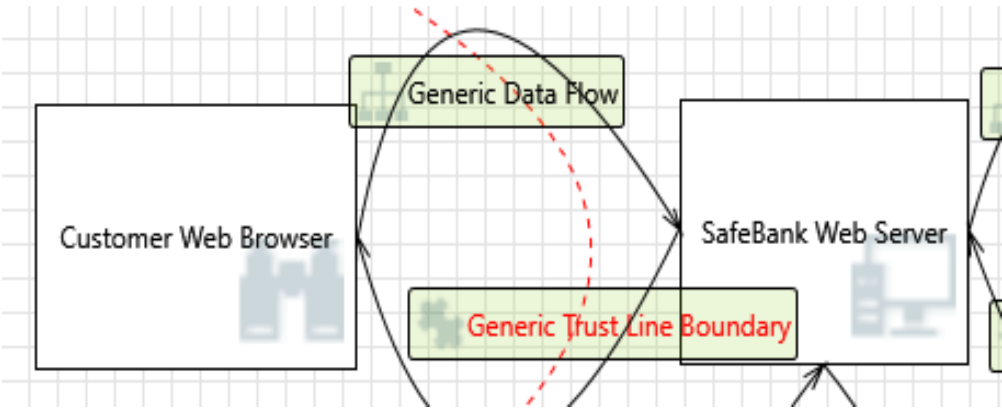
Diagram: Safe Baking



Safe Baking Diagram Summary:

Not Started	0
Not Applicable	0
Needs Investigation	0
Mitigation Implemented	24
Total	24
Total Migrated	0

Interaction: Generic Data Flow



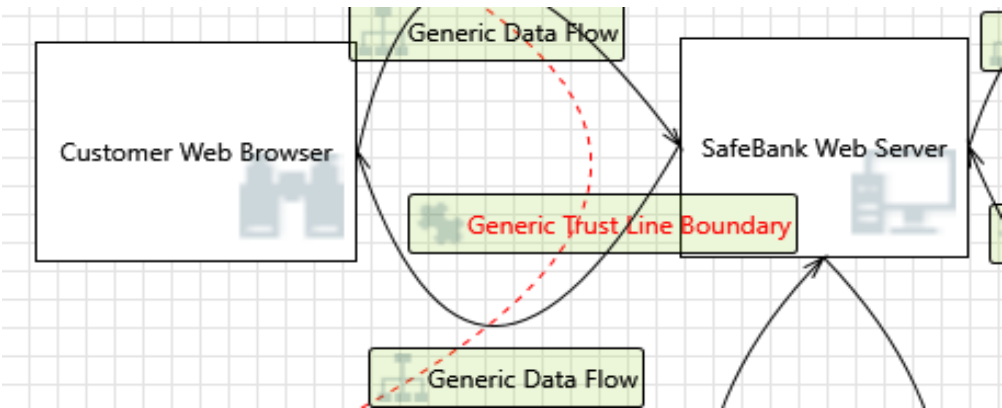
1. External Entity SafeBank Web Server Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: High]

Category	Repudiation
Description	SafeBank Web Server claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

2. Data Flow Generic Data Flow Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

Interaction: Generic Data Flow



3. External Entity Customer Web Browser Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: High]

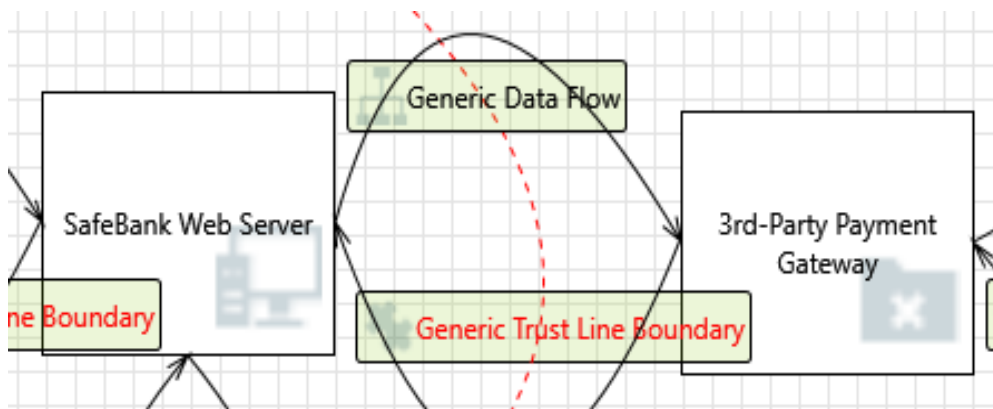
Category	Repudiation
----------	-------------

Description	Customer Web Browser claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

4. Data Flow Generic Data Flow Is Potentially Interrupted *[State: Mitigation Implemented] [Priority: High]*

Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

Interaction: Generic Data Flow



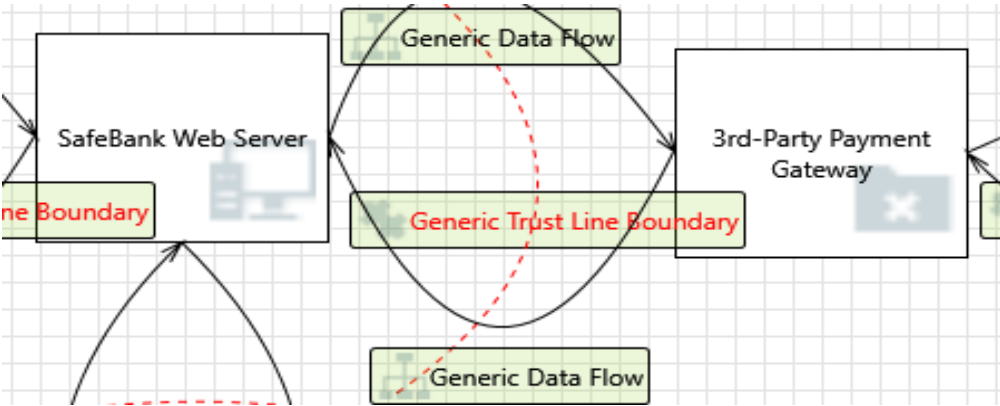
5. External Entity 3rd-Party Payment Gateway Potentially Denies Receiving Data *[State: Mitigation Implemented] [Priority: High]*

Category	Repudiation
Description	3rd-Party Payment Gateway claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

6. Data Flow Generic Data Flow Is Potentially Interrupted *[State: Mitigation Implemented] [Priority: High]*

Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

Interaction: Generic Data Flow



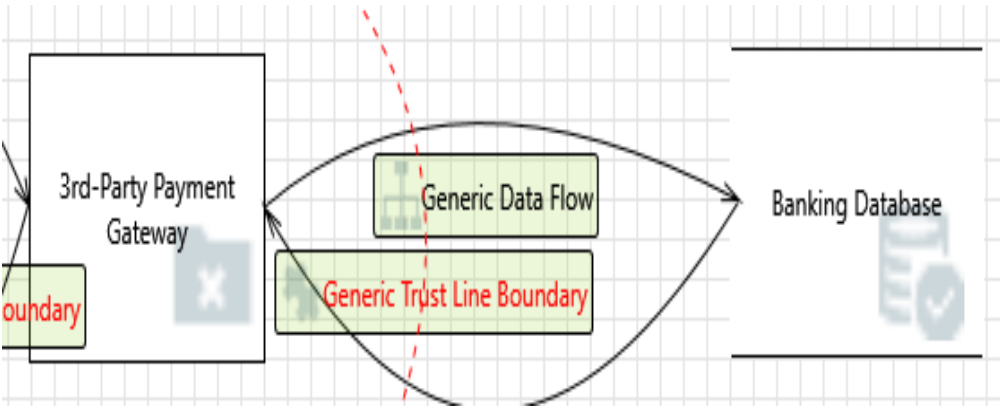
7. External Entity SafeBank Web Server Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: High]

Category	Repudiation
Description	SafeBank Web Server claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

8. Data Flow Generic Data Flow Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

Interaction: Generic Data Flow



9. Spoofing of Destination Data Store Banking Database [State: Mitigation Implemented] [Priority: High]

Category	Spoofing
----------	----------

Description	Banking Database may be spoofed by an attacker and this may lead to data being written to the attacker's target instead of Banking Database. Consider using a standard authentication mechanism to identify the destination data store.
Justification	Implement Multi-Factor Authentication (MFA) for all user logins.

10. Possible SQL Injection Vulnerability for Banking Database *[State: Mitigation Implemented] [Priority: High]*

Category	Tampering
Description	SQL injection is an attack in which malicious code is inserted into strings that are later passed to an instance of SQL Server for parsing and execution. Any procedure that constructs SQL statements should be reviewed for injection vulnerabilities because SQL Server will execute all syntactically valid queries that it receives. Even parameterized data can be manipulated by a skilled and determined attacker.
Justification	Use parameterized SQL queries to prevent database injection attacks.

11. The Banking Database Data Store Could Be Corrupted *[State: Mitigation Implemented] [Priority: High]*

Category	Tampering
Description	Data flowing across Generic Data Flow may be tampered with by an attacker. This may lead to corruption of Banking Database. Ensure the integrity of the data flow to the data store.
Justification	Use parameterized SQL queries to prevent database injection attacks.

12. Data Store Denies Banking Database Potentially Writing Data *[State: Mitigation Implemented] [Priority: High]*

Category	Repudiation
Description	Banking Database claims that it did not write data received from an entity on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

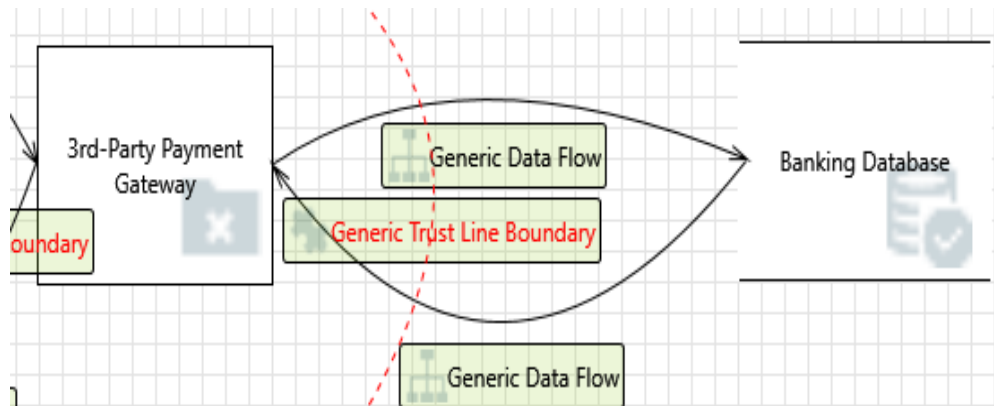
13. Data Flow Generic Data Flow Is Potentially Interrupted *[State: Mitigation Implemented] [Priority: High]*

Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

14. Data Store Inaccessible *[State: Mitigation Implemented] [Priority: High]*

Category	Denial Of Service
Description	An external agent prevents access to a data store on the other side of the trust boundary.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

Interaction: Generic Data Flow



15. Spoofing of Source Data Store Banking Database [State: Mitigation Implemented] [Priority: High]

Category	Spoofing
Description	Banking Database may be spoofed by an attacker and this may lead to incorrect data delivered to 3rd-Party Payment Gateway. Consider using a standard authentication mechanism to identify the source data store.
Justification	Implement Multi-Factor Authentication (MFA) for all user logins.

16. Weak Access Control for a Resource [State: Mitigation Implemented] [Priority: High]

Category	Information Disclosure
Description	Improper data protection of Banking Database can allow an attacker to read information not intended for disclosure. Review authorization settings.
Justification	Enforce HTTPS/TLS encryption for all data moving between the browser and server.

17. External Entity 3rd-Party Payment Gateway Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: High]

Category	Repudiation
Description	3rd-Party Payment Gateway claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

18. Data Flow Generic Data Flow Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

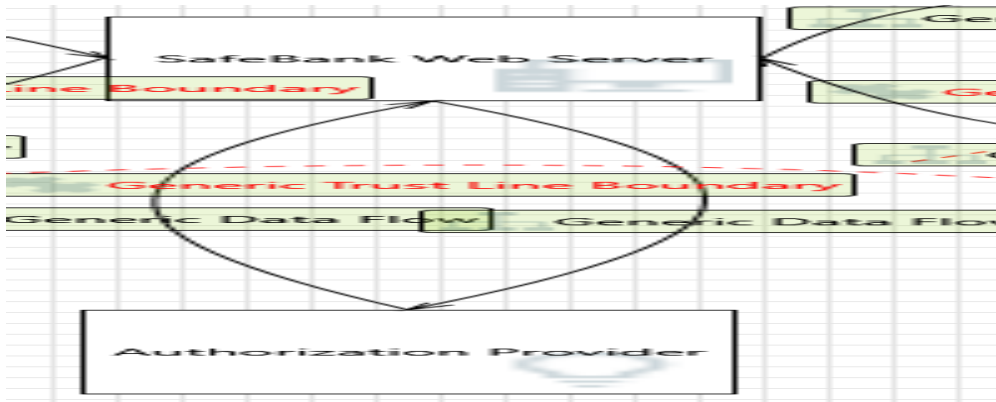
Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

19. Data Store Inaccessible [State: Mitigation Implemented] [Priority: High]

Category	Denial Of Service
----------	-------------------

Description	An external agent prevents access to a data store on the other side of the trust boundary.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

Interaction: Generic Data Flow



20. Weakness in SSO Authorization [State: Mitigation Implemented] [Priority: High]

Category	Elevation Of Privilege
Description	Common SSO implementations such as OAUTH2 and OAUTH Wrap are vulnerable to MitM attacks.
Justification	Apply the Principle of Least Privilege (PoLP) by ensuring the Web Server only has the minimum database permissions required to function. Use Role-Based Access Control (RBAC)

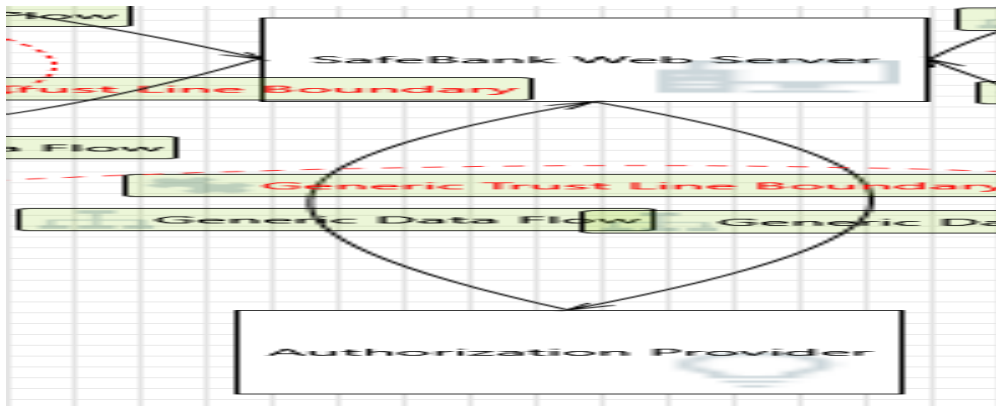
21. External Entity Authorization Provider Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: High]

Category	Repudiation
Description	Authorization Provider claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

22. Data Flow Generic Data Flow Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic

Interaction: Generic Data Flow



23. External Entity SafeBank Web Server Potentially Denies Receiving Data [State: Mitigation Implemented] [Priority: High]

Category	Repudiation
Description	SafeBank Web Server claims that it did not receive data from a process on the other side of the trust boundary. Consider using logging or auditing to record the source, time, and summary of the received data.
Justification	Implement robust digital logging and audit trails for all transactions, ensuring that every action is timestamped and linked to a verified user session

24. Data Flow Generic Data Flow Is Potentially Interrupted [State: Mitigation Implemented] [Priority: High]

Category	Denial Of Service
Description	An external agent interrupts data flowing across a trust boundary in either direction.
Justification	Implement rate limiting on the Web Application Server and use a Web Application Firewall (WAF) to filter out malicious traffic